UNIVERSIDAD POLITÉCNICA DE DURANGO

UNIT I

SOFTWARE MANAGEMENT PROJECTS

REQUIREMENTS SPECIFICATION V3

SOFTWARE ENGINEERING



TEACHER NAME: JOSE LUIS BAUTISTA

STUDENTS' NAMES: LEONEL DE LA CRUZ FLORES - EMILIO RANGEL TORRES - FERNANDO CISNEROS TORRES - HECTOR TORRES CARRIZALES

9B BIS ISW

21/09/2026

Content

Content
Document Control
Introduction
Purpose
Project Background
Problem Addressed
Intended Users
Definitions and Terminology
Product Overview
Product Objectives
Actors
System Boundaries
Assumptions
Constraints
Dependencies
Role Permissions Matrix
Scope
In-scope functionality
Out-of-scope functionality
Future functionality
Current Situation
As-Is Process
Current Problems
Opportunities
Proposed Solution
To-Be Process
Expected Capabilities
Functional Requirements
Non-functional Requirements
Business Roles
AI Requirments
Use Cases
UC-001 - Upload Document
UC-002 - Ask Compliance Question
UC-003 - Manage Compliance Requirement
Requirements Prioritization

Requirements Quality Review.....
Examples of Requirement Defects.....
Audit Findings Resolution (V1 → V2).....
Requirements Traceability.....
Scope Verification.....
Open Issues.....
Approval and Validation.....

Document Control

This version (V3) consolidates the original Requirements Specification (V1, 21/09/2026) with the findings and corrections of the Requirements Specification Audit (23/09/2026). Requirement IDs from V1 are preserved to maintain traceability. A detailed record of how each audit finding was resolved is included in Section 12.2.

Version	Date	Description
V1	21/09/2026	Initial Software Requirements Specification.
Audit	23/09/2026	Requirements quality audit: individual requirements, conflicts, incomplete areas, non-functional coverage, traceability, and clarification questions.
V2	28/09/2026	Corrected requirements from the audit; standardized terminology and priorities; added permissions matrix, glossary, expanded traceability matrix, audit resolution log, and consolidated open issues.
V3 (Draft)	19/10/2026	Resolved deployment and operations open issues (OI-07, OI-15, OI-16, OI-17) through ADR-030, ADR-031, ADR-032, and ADR-033. Established production deployment infrastructure (DigitalOcean VPS 4 vCPU/8 GB RAM), normal-load profile (100 concurrent users; 50/20/10/10/10% distribution), maintenance window (Sundays 02:00-04:00 America/Mexico_City; 1-min health check downtime rule), and disaster recovery targets (RTO 4h, RPO 24h, GPG AES-256 pre-upload encryption).

Introduction

Purpose

The purpose of this document is to define the requirements for a web-based Compliance Management and Document Intelligence System. The system will help an organization manage internal policies, regulations, documents, and compliance activities. It will also include an AI

assistant that can answer questions using information from authorized organizational knowledge sources. This document describes what the system must do, who will use it, and the main conditions and limitations of the project.

Project Background

Organizations can have many policies, contracts, regulations, and internal documents. Employees sometimes need to read long documents or ask Compliance Staff when they do not know which policy applies to their situation. The proposed system will centralize this information and make it easier to find. It will also use AI and document retrieval to provide answers based on the organization's own documents.

Problem Addressed

The current process depends too much on manual document searches and on administrative and compliance staff. Information can also be difficult to find because documents can be distributed in different locations or stored as scanned files. The system will reduce these problems by centralizing documents, managing their versions, tracking compliance requirements, and providing an AI assistant with document references.

Intended Users

The main users are:

- General Employees
- Compliance Staff (referred to as "administrative staff" in the current process)
- Administrators
- Organization Management

External legal advisors are secondary stakeholders because they can provide legal documents, but they will not normally use the system directly.

Definitions and Terminology

The audit identified that the same concepts were named in different ways across V1. The following terms are used consistently throughout this version.

Team	Definition
Authorized organizational knowledge sources	The set of processed documents of the organization that the current user is authorized to access. Replaces "authorized information", "authorized documents", "knowledge base", and "knowledge sources" used in V1.
Compliance Staff	Role responsible for managing documents and compliance requirements. Replaces "administrative staff" and "authorized staff" used in V1.
Current version	The most recent version of a document that passed validation and processing successfully (FR-005).
Document-based response	An AI response generated from content retrieved from authorized organizational knowledge sources.
Insufficient-information response	The AI response returned when no sufficient authorized information is retrieved (NFR-018, AIR-005).
Missing document	A document required by a compliance requirement that is not satisfied by any associated uploaded document (FR-014).
Normal-load test profile	Documented workload (concurrent users and request distribution) used to verify NFR-008, NFR-009 and NFR-011 (OI-15).
Notification period	Configured time before a deadline or expiration date at which an alert is generated (FR-015).
Processing Failed	Document status assigned when text extraction, OCR, or queueing fails (FR-003, NFR-010).

Product Overview

Product Objectives

The objectives are identified with codes so they can be traced in Section 13.

ID	Objective
SO-01	Centralize organizational and compliance documents, making them easier to manage and maintaining their version history.
SO-02	Improve information retrieval, allowing employees to find information through search and natural-language questions.
SO-03	Improve compliance tracking of requirements, deadlines, and required documents.
SO-04	Protect confidential organizational information and maintain audit records.
SO-05	Reduce AI hallucinations by providing answers supported by the organization's documents.

Actors

Actor	Main responsability
Administrator	Manage organization and users
Compliance Staff	Manage documents and compliance requirements
General Employee	Ask questions and consult authorized information
Management	Review compliance information (role mapping pending, see OI-14)
AI Assistant	System actor that retrieves information and generates document-based answers

System Boundaries

The system will work as an internal web platform.

Input: documents uploaded by authorized Compliance Staff; natural-language questions from employees; organization and compliance information.

Processing: document processing; information retrieval; compliance management; AI-assisted question answering.

Output: document-based answers; citations; compliance information; in-application alerts; audit records.

Assumptions

- Users will have access to a modern web browser.
- The organization will provide documents for testing.
- Server infrastructure will be available.
- An authorized AI model will be available for the project.
- Users will have the required permissions for their activities.

Constraints

- The project must be completed during the academic semester.
- The project has a limited budget.
- Confidential documents cannot be sent to AI services not authorized by the organization (NFR-004).
- The project will use Laravel, FastAPI, and PostgreSQL.
- The initial version will be a web application and not a native mobile application.

Dependencies

The system depends on:

- PostgreSQL
- Document processing tools
- OCR technology for scanned documents
- AI/LLM service
- Embedding model
- Vector storage
- Server infrastructure

Role Permissions Matrix

The audit found that the roles were defined but their permissions were not. The following matrix is the baseline referenced by FR-002, FR-008, FR-016 and FR-018. It must be confirmed by stakeholders before development (OI-14).

Function	Administrator	Compliance staff	General employee
Manage organization and users	Yes	No	No
Upload documents	Yes	Yes	No
Manage document versions	Yes	Yes	No
Manage compliance requirements and criteria	Yes	Yes	No
Change compliance status	No	Yes	No
View compliance dashboard	Yes	Yes	Authorized by
Ask AI questions	Yes	Yes	Yes
View audit logs	Yes	Defined by policy	No

Scope

In-scope functionality

- Organization registration and user account management
- Authentication and role-based access control (Administrator, Compliance Staff, General Employee)
- Document upload (PDF, DOCX, TXT), metadata, version control, archiving
- Text extraction and OCR for scanned PDFs, including processing-failure handling
- AI/RAG assistant for natural-language questions with citations and disclaimers
- Compliance requirements, applicability criteria, dashboard, statuses, missing documents, evidence
- In-application alerts for deadlines and document expiration

- Search and filtering
- Audit logging and security controls
- Feedback on AI answers

Out-of-scope functionality

- Integration with external ERP or HRMS systems
- Automated legal document generation
- Autonomous legal advice or legal decision-making
- Electronic document signing
- Native mobile application
- Transmission of documents to unauthorized external AI providers
- Advanced OCR (handwriting, complex table reconstruction)

Future functionality

- Support for languages other than English (documents, UI, and AI answers)
- Email notifications (version 1 uses in-application alerts only)
- Exportable compliance reports
- Review workflow for flagged AI answers
- Chat history per user

Current Situation

As-Is Process

Currently, employees usually need to search through long manuals or ask administrative staff when they need information about a policy or regulation. The general process can be represented as:

Employee → Search documents / Ask administrative staff → Manual review → Answer

Documents can also be stored in different locations and some of them may be scanned PDFs, which makes searching more difficult.

Current Problems

- Documents are fragmented.
- Some documents are difficult to search.
- Employees spend a lot of time reading manuals.
- Administrative staff answer repetitive questions.
- It is difficult to track document versions.
- Compliance activities are not centralized.
- Employees can misunderstand outdated information.

Opportunities

The main opportunity is to centralize the information and provide a faster way to access it. AI can also help users ask questions in natural language instead of searching manually.

Proposed Solution

To-Be Process

Information retrieval: Employee → System → Question → Document Retrieval → AI Response → Citation → Employee

Compliance management: Compliance Staff → Upload Document → Processing → Storage → Compliance Management → Dashboard / Alerts

The AI will support the user, but it will not make autonomous legal decisions.

Expected Capabilities

The system shall allow authorized users to manage documents and compliance requirements according to their role. Employees shall be able to ask questions and receive answers based on authorized organizational knowledge sources. AI responses must include references to the source documents when the answer comes from those documents.

Functional Requirements

Priorities use the MoSCoW classification defined in Section 11, which is now the single authoritative priority scheme of this document.

ID	Functional Requirement	Priority	Source	Acceptance Criteria
FR-001	The system shall allow administrators to register an organization by providing its legal name, organization type, industry, location, number of employees, and business activities. The system shall reject the registration when a required field is empty or does not comply with its defined data format or validation rule.	Must	Stakeholder Needs / Project Requirements	The organization shall not be saved if any of the six required fields is empty or fails its validation rule; the system shall indicate which field must be corrected. After successful registration, all six fields shall be stored and displayed correctly. Allowed values and formats are defined per OI-09.
FR-002	The system shall allow users with document-upload permission (Section 2.7) to upload PDF, DOCX, and TXT files with a maximum size of 25 MB (26,214,400 bytes) per file. Files with unsupported extensions, unsupported MIME types, or a size greater than 25 MB shall be rejected and the system shall display the reason for rejection.	Must	Project Requirements / Document Management	A PDF, DOCX, or TXT file of 26,214,400 bytes or less with a matching MIME type shall be uploaded successfully. A file with an unsupported extension or MIME type, or larger than 26,214,400 bytes, shall be rejected and the specific rejection reason shall be displayed.
FR-003	The system shall automatically extract text from supported text-based documents. For scanned PDFs without selectable text,	Should	AS-IS / TO-BE Analysis / Document Processing	Text-based documents shall have their text extracted automatically. A scanned PDF without selectable text shall be processed with OCR and its text shall be

ID	Functional Requirement	Priority	Source	Acceptance Criteria
	the system shall use OCR. If text extraction or OCR fails, the system shall mark the document as "Processing Failed" and show that status to authorized users.			available for indexing and search. A document whose extraction fails shall display the "Processing Failed" status and shall not be indexed.
FR-004	The system shall store the document name, category, version, upload date, expiration date (when applicable), and uploading user for each document. Required metadata shall be validated before the document is stored.	Must	Document Management Requirements	A document shall not be stored if its name, category, or version is missing. Upload date and uploading user shall be recorded automatically. The expiration date shall be stored when provided. All stored metadata shall be displayed when an authorized user views the document information.
FR-005	The system shall maintain the version history of each document. When a new version is uploaded, the previous version shall remain accessible through the version history, and the new version shall become the current version after successful validation and processing.	Must	Stakeholder Needs / Document Management	After a new version is uploaded and processed successfully, it shall be marked as current and the previous version shall remain listed and accessible in the version history. If the new version fails validation or processing, the previous version shall remain the current version.
FR-006	The system shall allow authorized Compliance Staff to create a compliance requirement with a name, description, applicable regulation, deadline, required documents, responsible user, and	Must	Compliance Tracking Requirements	A compliance requirement shall not be created if any required field is missing or invalid, or if the initial status is not one of the BR-004 statuses. A valid requirement shall store all specified information and display its initial status. Later

ID	Functional Requirement	Priority	Source	Acceptance Criteria
	initial status. The initial status shall be one of the statuses defined in BR-004.			status changes are governed by FR-016.
FR-007	The system shall determine which compliance requirements apply to an organization using predefined regulatory criteria associated with the organization's registered characteristics. When organization information is created or updated, the system shall evaluate the applicable criteria and display the matching compliance requirements. Authorized Compliance Staff shall be able to maintain the regulatory criteria used for this evaluation.	Must	Compliance Rules / TO-BE Process	After organization information is created or updated, the system shall display exactly the compliance requirements whose configured criteria match the organization characteristics. A criteria change saved by Compliance Staff shall be applied in the next evaluation. The specific characteristics and criteria are defined per OI-08.
FR-008	The system shall provide a compliance dashboard to authenticated users with compliance-dashboard permission. The dashboard shall display the applicable requirements, deadlines, required documents, and current compliance status for the organization the user is authorized to access.	Must	Stakeholder Needs / TO-BE Process	A user with dashboard permission shall see the applicable requirements, deadlines, required documents, and status, and the information shown shall match the stored compliance data. A user without dashboard permission shall be denied access.
FR-0	The system shall allow	Shou	AS-IS /	When a user applies a

ID	Functional Requirement	Priority	Source	Acceptance Criteria
09	authorized users to search and filter documents and compliance requirements by name, category, status, applicable regulation, and the date fields defined for each record type (documents: upload date and expiration date; compliance requirements: deadline).	ld	TO-BE Analysis / User Needs	search or filter, the system shall display only records that match all selected criteria and that the user is authorized to access. If no records match, the system shall indicate that no results were found.
FR-010	The system shall provide a natural-language chat interface through which authenticated employees can submit questions about organizational policies and compliance information available in documents they are authorized to access.	Must	Stakeholder Needs / AI Assistant	An authenticated employee shall be able to enter and submit a natural-language question. The response shall be generated only from the authorized organizational knowledge sources of that user.
FR-011	For a document-related question, the AI service shall retrieve relevant sections from the user's authorized organizational knowledge sources before generating a response. The generated response shall be based on the retrieved information.	Must	AI Integration Proposal / RAG Requirements	For a document-related question, the system logs shall show that retrieval was executed before generation and that only fragments from documents the user is authorized to access were retrieved. The relevance threshold used to accept retrieved sections is defined per OI-05.
FR-012	Every document-based AI response shall identify the source	Must	Stakeholder Needs / AI	In the AI evaluation set (AIR-008), 100% of document-based responses

ID	Functional Requirement	Priority	Source	Acceptance Criteria
	document and, when available, the page number, section, or document location containing the information supporting the response. The citation shall identify the specific retrieved content used to generate the response.		Requirements	shall include at minimum the source document name, and the page, section, or location whenever the source document provides it. Each citation shall correspond to a fragment that was actually retrieved for that response.
FR-013	When an authorized user selects an AI citation, the system shall display the corresponding location or extracted content supporting the response. The system shall verify the user's authorization before displaying the referenced document content.	Should	Stakeholder Needs / AI Assistant	Selecting a citation shall open the corresponding document location or extracted text. If the user is not authorized to view the referenced document, the system shall deny access and shall not display its content.
FR-014	The system shall identify a required compliance document as missing when no uploaded document associated with the compliance requirement satisfies the defined document type or requirement.	Must	Compliance Tracking / TO-BE Process	When a compliance requirement lists a required document and no associated uploaded document satisfies it, the system shall display a "Missing Document" indication for that requirement. The indication shall disappear once a satisfying document is associated. The matching rule is defined per OI-13.
FR-015	The system shall generate an in-application alert when a configured notification period is reached before a compliance	Should	Compliance Tracking Requirements	When the configured notification period is reached, an in-application alert shall be visible to the responsible user containing the affected item, its

ID	Functional Requirement	Priority	Source	Acceptance Criteria
	deadline or document expiration date. The alert shall identify the affected compliance requirement or document, the applicable deadline or expiration date, and the responsible user.			deadline or expiration date, and the responsible user. Supported notification periods are defined per OI-04.
FR-016	The system shall allow authorized Compliance Staff to change a compliance requirement status to Compliant, Pending, At Risk, or Overdue. The selected status shall be stored and displayed in the compliance dashboard.	Must	Compliance Tracking Requirements	A Compliance Staff user shall be able to select one of the four allowed statuses; the status shall be saved, immediately displayed in the dashboard, and recorded in the audit log (FR-017). Users without this permission shall be denied.
FR-017	The system shall record audit events for document uploads, document version changes, compliance requirement changes, and compliance status changes. Each event shall include the authenticated user, action, affected resource, and timestamp. Security-sensitive events shall additionally include the information required by NFR-014.	Must	Security / Audit Requirements	Each listed action shall generate an audit record containing the authenticated user, action, affected resource, and date and time. Security-sensitive events shall also satisfy NFR-014.
FR-018	The system shall enforce role-based access control for Administrators, Compliance Staff, and General Employees.	Must	Stakeholder Needs / Security Requirements	For every function in the permissions matrix (Section 2.7), a user of each role shall only be able to perform the actions marked as allowed. Attempts to access

ID	Functional Requirement	Priority	Source	Acceptance Criteria
	Each role shall have explicitly defined permissions for system functions and organizational information, as specified in Section 2.7. Unauthorized attempts to access restricted functions or information shall be denied and recorded as required by NFR-014.			other functions or documents shall be denied and recorded in the audit log.

Non-functional Requirements

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
NFR-001	Sensitive personal and organizational data (passwords, email addresses, phone numbers, organization legal information, and responsible-user information) shall be protected using security mechanisms appropriate to the type of data. User passwords shall be stored using a secure password-hashing mechanism and shall never be stored as plaintext.	Must	Security Requirements / Stakeholder Needs	Database inspection shall confirm that no password is stored in plaintext or with reversible encryption, and that the protection mechanism defined for each sensitive field is applied.
NFR-002	Confidential organizational documents shall be encrypted at rest. Direct	Must	Security Requirements / Project	Stored document files shall be unreadable without decryption by the application. An attempt to

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	access to stored document files shall be prohibited unless authorized through the application's access-control mechanism.		Scope	obtain a stored file without passing the application authorization process shall fail.
NFR-003	All client-server communication containing authentication credentials or organizational data shall use HTTPS. HTTP requests to protected resources shall be rejected or redirected to HTTPS without transmitting sensitive information over unencrypted HTTP.	Must	Security Requirements	Requests to protected resources shall only be served over HTTPS. An HTTP request to a protected resource shall be rejected or redirected, and no credentials or organizational data shall appear in the unencrypted traffic.
NFR-004	Confidential documents shall only be transmitted to AI services explicitly approved by the organization. The system configuration shall identify which AI services are authorized to process organizational documents.	Must	Project Constraints / Stakeholder Needs	The system configuration shall contain the list of authorized AI services. Testing shall confirm that no confidential document or fragment is sent to a service outside that list.
NFR-005	The system shall require users to authenticate before accessing organizational information and documents.	Must	Security Requirements / Access Control	An unauthenticated user shall not be able to access protected documents or organizational information. The system shall require authentication before granting access.
NFR-006	The system shall lock an account for 15	Should	Security Requirem	After the fifth consecutive failed login attempt, the

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	minutes after 5 consecutive failed authentication attempts.		ents	account shall be blocked for 15 minutes. During the lockout, valid credentials shall not allow login until the lockout expires.
NFR-007	The system shall automatically terminate inactive user sessions after 30 minutes.	Should	Security Requirements	A session with no user activity for 30 minutes shall become invalid, and the user shall be required to authenticate again to access protected resources.
NFR-008	Under the defined normal-load test profile, at least 95% of standard operations, excluding AI inference and document processing, shall complete within 2 seconds. The normal-load profile shall specify the number of concurrent users and the representative request distribution before performance testing.	Should	Performance Requirements	A performance test executed with the documented normal-load profile (OI-15) shall show that at least 95% of standard requests complete within 2 seconds.
NFR-009	Under the defined normal-load test profile, at least 90% of AI questions shall receive a response within 10 seconds. The normal-load profile shall specify the number of concurrent users and the representative AI-question workload.	Should	AI Requirements / Performance Requirements	A performance test executed with the documented normal-load profile (OI-15) shall show that at least 90% of AI questions receive a response within 10 seconds.
NFR-010	After a successful upload, every valid document shall enter	Should	Document Processing	Queue timestamps shall show that valid documents enter the processing queue

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	the document-processing queue within 5 seconds. If the document cannot enter the queue, the system shall record a processing failure and notify the authorized user.		Requirements	within 5 seconds of upload completion. A document that cannot be queued shall show a processing failure to the uploading user.
NFR-011	The system shall support at least 100 concurrent authenticated users while meeting the response-time requirements defined in NFR-008 and NFR-009.	Should	Performance Requirements	A load test with at least 100 concurrent authenticated users shall demonstrate that both NFR-008 and NFR-009 continue to be met.
NFR-012	The system shall maintain at least 99% monthly availability, excluding scheduled maintenance periods that are defined and documented before the measurement period.	Should	Availability Requirements	Monthly monitoring shall demonstrate at least 99% availability outside the maintenance periods documented in advance (OI-16).
NFR-013	The system shall prevent unauthorized modification or deletion of document versions and audit records.	Must	Security / Audit Requirements	Users without the required permissions shall not be able to modify or delete protected document versions or audit records. Authorized users shall only perform actions allowed by their role.
NFR-014	The system shall record security-sensitive operations (including authentication attempts, access denials, and permission changes) in an audit log containing the authenticated user, action, affected	Must	Security / Audit Requirements	Each security-sensitive operation shall create an audit record containing all five values. An attempt by an unauthorized user to modify an audit record shall be denied.

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	resource, IP address, and timestamp. Audit records shall not be modifiable by unauthorized users.			
NFR-015	The system shall automatically perform at least one database backup every 24 hours. Each completed backup shall have a recorded creation date and time, and backup completion shall be monitored for failures.	Must	Security / Data Protection Requirements	At least one successful backup with a recorded creation date and time shall exist for every 24-hour period. A failed backup shall be detected and reported by the monitoring process.
NFR-016	The system shall retain database backups for at least 30 days. The organization shall define and test a backup restoration procedure to verify that retained backups can be restored successfully.	Should	Data Protection Requirements	Backup storage shall contain backups covering at least the previous 30 days, and the documented restoration procedure shall successfully restore a selected backup during testing.
NFR-017	The system shall validate uploaded files against the supported file extensions and MIME types defined for PDF, DOCX, and TXT. Files identified as executable or otherwise invalid shall be rejected before permanent storage.	Must	Security / File Validation Requirements	A file shall be accepted only when both its extension and MIME type correspond to PDF, DOCX, or TXT. Executable files and files with mismatched or unsupported MIME types shall be rejected before being stored.
NFR-018	For compliance-related questions, the AI assistant shall generate responses using information retrieved	Must	AI Requirements / Hallucination	In the AI evaluation set, questions with supporting documents shall be answered from the retrieved content, and questions

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	from authorized organizational knowledge sources. When sufficient authorized information is not available, the system shall indicate that sufficient information was not found instead of presenting unsupported compliance information as fact.		Prevention	without supporting documents shall return the insufficient-information message. Thresholds are defined per OI-05.
NFR-019	Each indexed document fragment shall maintain a reference to its original document and version. When page or section information exists in the source document, that information shall also be stored.	Must	AI/RAG Requirements / Traceability	Every indexed fragment shall be traceable to its original document and version, and to its page or section whenever the source document contains that information.
NFR-020	The system shall support the latest two stable versions of Google Chrome, Microsoft Edge, Mozilla Firefox, and Safari available at the time of each defined compatibility test cycle.	Could	System Constraints / Compatibility Requirements	All core functions shall pass compatibility tests on the latest two stable versions of each browser, identified at the start of each test cycle.
NFR-021	The system shall use PostgreSQL for persistent application data and shall enforce defined foreign-key relationships through database constraints. Attempts to create records violating those relationships shall be	Must	Technology Constraints	PostgreSQL shall be the persistent database, and inserting or updating a record that violates a defined foreign-key relationship shall be rejected by the database.

ID	Non-Functional Requirement	Priority	Source	Acceptance Criteria
	rejected.			
NFR-022	The system shall separate the web application and AI processing services through defined service interfaces between Laravel and FastAPI.	Must	Architecture / Technology Constraints	AI operations shall communicate through defined FastAPI service interfaces. Laravel shall not directly contain the AI processing logic, and the interfaces shall be usable independently from the Laravel application code.

Business Roles

ID	Business Rule	Related
BR-001	Only users with document-upload permission can upload organizational documents.	FR-002, FR-018
BR-002	Users can only access documents allowed by their role.	FR-018, AIR-006
BR-003	A new document version must not delete the previous version.	FR-005
BR-004	Compliance requirements can only have the statuses Compliant, Pending, At Risk, or Overdue.	FR-006, FR-016
BR-005	AI answers about compliance must be based on authorized organizational knowledge sources.	FR-011, NFR-018
BR-006	The AI assistant does not replace professional legal advice.	AIR-007
BR-007	When sufficient information is not available, the AI assistant must indicate that the information was not found.	NFR-018, AIR-005
BR-008	Security-sensitive actions must be recorded in the audit log.	NFR-014
BR-009	An AI citation must never give access to content of a document the user is not authorized to view.	FR-013, FR-018
BR-010	Confidential documents may only be processed by AI services listed as authorized in the system configuration.	NFR-004

AI Requirments

AIR-001 - Natural Language Questions

The system shall allow authorized employees to submit questions about organizational policies and compliance information using natural language. (Related: FR-010)

AIR-002 - Document Retrieval

The AI service shall retrieve relevant sections from the user's authorized organizational knowledge sources before generating a response. (Related: FR-011)

AIR-003 - Grounded Responses

The AI assistant shall generate answers using the retrieved information and shall not present unsupported regulatory information as fact. (Related: NFR-018)

AIR-004 - Source Citations

The AI response shall identify the source document and, when available, the page number, section, or document location used for the answer, following the same citation rules as FR-012.

AIR-005 - Insufficient Information

If the system does not retrieve sufficient authorized information, the assistant shall return an insufficient-information response instead of an unsupported answer. (Related: NFR-018, BR-007)

AIR-006 - Access Control

The AI retrieval process shall only use documents that the current user is authorized to access, including when citations are opened. (Related: FR-013, FR-018)

AIR-007 - Human Control

The AI output shall be considered assistance and information retrieval. It shall not make autonomous legal or compliance decisions. (Related: BR-006)

AIR-008 - AI Evaluation

AI responses shall be tested using a defined evaluation set of questions based on the organization's documents, including questions with and without supporting documents. The evaluation shall measure answer relevance, source accuracy, and citation traceability against acceptance thresholds defined before testing (OI-05).

Use Cases

UC-001 - Upload Document

Primary Actor: Compliance Staff

Goal: Upload a new organizational document or a new version of an existing one.

Preconditions:

- The user is authenticated.
- The user has document-upload permission (Section 2.7).

Main Flow:

1. The user selects the upload option.
2. The system displays the upload form.
3. The user selects a document and enters its metadata.
4. The system validates the file extension, MIME type, file size, and required metadata.
5. The system stores the document encrypted at rest together with its metadata.
6. The system places the document in the processing queue.
7. The system confirms the upload.

Alternative Flows:

- If the file is larger than 25 MB, has an unsupported extension or MIME type, or is executable, the system rejects it and displays the reason.
- If required metadata is missing, the system does not store the document and indicates which field must be completed.
- If the document is a scanned PDF without selectable text, the system uses OCR to extract its text.
- If extraction, OCR, or queueing fails, the system marks the document as "Processing Failed" and shows the status to the user; the previous version, if any, remains current.

Postcondition: The document is stored with its metadata and is available for processing and version management.

Related Requirements: FR-002, FR-003, FR-004, FR-005, FR-017, NFR-002, NFR-010, NFR-017.

UC-002 - Ask Compliance Question

Primary Actor: General Employee

Goal: Get information about a policy or compliance topic.

Preconditions:

- The user is authenticated.

- The user has access to at least one authorized organizational knowledge source.

Main Flow:

1. The employee opens the AI assistant.
2. The employee enters a question in natural language.
3. The system receives the question.
4. The system retrieves relevant sections from the user's authorized organizational knowledge sources.
5. The AI assistant generates a response using the retrieved information.
6. The system displays the answer.
7. The system displays the citation: source document and, when available, the page, section, or location.
8. The employee can select the citation to view the supporting content.

Alternative Flows:

- If no sufficient authorized information is retrieved, the system returns an insufficient-information response instead of presenting unsupported compliance information as fact.
- If the employee selects a citation to a document they are not authorized to view, the system denies access.

Postcondition: The employee receives a document-based answer with a source citation, or an insufficient-information response.

Related Requirements: FR-010, FR-011, FR-012, FR-013, NFR-009, NFR-018, AIR-001 to AIR-006.

UC-003 - Manage Compliance Requirement

Primary Actor: Compliance Staff

Goal: Create and track a compliance requirement.

Preconditions:

- The user is authenticated.
- The user has compliance-management permission (Section 2.7).

Main Flow:

1. The user selects the option to create a compliance requirement.
2. The system displays the required fields.

3. The user enters the name, description, applicable regulation, deadline, required documents, responsible user, and initial status.
4. The system validates the information.
5. The system saves the compliance requirement and records the action in the audit log.
6. The system evaluates the regulatory criteria to determine whether the requirement applies to the organization.
7. The requirement appears in the compliance dashboard.
8. The system displays the required documents, deadline, and current status.

Alternative Flows:

- If required information is missing or invalid, the system does not save the requirement and informs the user which information must be corrected.
- If a required document has not been uploaded, the system identifies it as a missing document.
- When the configured notification period is reached, the system generates an in-application alert for the responsible user.
- Compliance Staff can later change the status to any of the BR-004 statuses.

Postcondition: The compliance requirement is stored and can be tracked by authorized users through the compliance dashboard.

Related Requirements: FR-006, FR-007, FR-008, FR-014, FR-015, FR-016, FR-017.

Requirements Prioritization

This project uses the MoSCoW method. In V1, individual requirements used Critical/High/Medium while this section used MoSCoW, and both classifications did not align (for example, OCR and alerts were High individually but Should in MoSCoW). In V2 the MoSCoW classification below is the single authoritative priority, and it is applied directly in Sections 6 and 7.

Priority	Capabilities	Requirements
Must	Organization registration, authentication, document upload and management, compliance requirements and applicability, dashboard, status management, AI	FR-001, FR-002, FR-004 to FR-008, FR-010 to FR-012, FR-014, FR-016 to FR-018; NFR-001 to NFR-005, NFR-013 to NFR-015, NFR-017 to

Priority	Capabilities	Requirements
	chat, retrieval and citations, AI grounding, access control, audit logs, security, backups, architecture	NFR-019, NFR-021, NFR-022
Should	OCR, search and filtering, citation viewer, alerts, account lockout, session timeout, performance, availability, backup retention	FR-003, FR-009, FR-013, FR-015; NFR-006 to NFR-012, NFR-016
Could	Extended browser compatibility, advanced reports, more advanced OCR	NFR-020
Won't	Native mobile app, autonomous legal decisions, electronic signatures, external ERP/HRMS integration	Out of scope (Section 3.2)

The AI assistant and document management have Must priority because they are central to the purpose of the project. OCR and alerts are Should because the system remains usable with text-based documents and the dashboard while they are completed.

Requirements Quality Review

Examples of Requirement Defects

Requirement	Problem	Type	Proposed Correction
"The system should be fast."	It does not define how fast.	Ambiguous	Complete standard operations within 2 seconds for 95% of requests under the normal-load profile (NFR-008).
"The system shall generate reports."	It does not specify which reports or information.	Incomplete	Define the report type, information, and users that can access it.
"Only administrators can modify records."	It conflicts with staff who need to update compliance records.	Conflicting	Define modification permissions by role (Section 2.7).
"The AI will be intelligent."	It cannot be tested clearly.	Unverifiable	Define AI inputs, outputs, sources, and evaluation criteria (AIR-008).
"The system shall manage	It is too broad.	Ambiguous	Separate upload, metadata, versioning,

Requirement	Problem	Type	Proposed Correction
documents."			processing, and retrieval requirements.
"The AI shall answer questions."	It does not define where the answers come from.	Incomplete	Require retrieval from authorized organizational knowledge sources.

Audit Findings Resolution (V1 → V2)

The following table records every finding of the Requirements Specification Audit and how it was resolved in this version. Findings that depend on stakeholder decisions are linked to an open issue (Section 15).

ID	Audit Finding	Severity	Resolution in V2
FR-001	Validation rules not defined	Medium	Rejection rule for invalid formats added; allowed values moved to OI-09.
FR-002	Size unit and error behavior imprecise	Low	Size fixed at 26,214,400 bytes; MIME validation and rejection reason added.
FR-003	OCR failure behavior missing	Medium	"Processing Failed" status added.
FR-004	Required metadata unclear	Medium	Mandatory vs. conditional fields defined; expiration date only when applicable.
FR-005	"Newest valid version" undefined	Medium	Current version defined as the one that passed validation and processing.
FR-006	Status overlap with FR-016	Medium	FR-006 defines initial status; FR-016 governs later changes.
FR-007	Matching logic undefined	High	Rewritten with criteria maintained by Compliance Staff; exact criteria in OI-08.
FR-008	"Required permission" undefined	Medium	Linked to permissions matrix (Section 2.7).
FR-009	"Date" ambiguous	Medium	Date fields defined per record type.
FR-010	Vague "authorized compliance information"	High	Terminology standardized (Section 1.5).
FR-011	"Relevant" not	High	Verifiable criterion added;

ID	Audit Finding	Severity	Resolution in V2
	measurable		relevance threshold in OI-05.
FR-012	"Enough citation information" subjective	High	Minimum citation fields defined; aligned with AIR-004.
FR-013	Possible authorization bypass	High	Authorization check added; BR-009 created.
FR-014	Missing-document matching undefined	Medium	Rule rewritten; matching detail in OI-13.
FR-015	Notification period and channel undefined	High	Channel fixed as in-application; periods in OI-04.
FR-016	"Authorized user" too broad	Medium	Restricted to Compliance Staff.
FR-017 / NFR-014	Duplicate audit logging	Medium	FR-017 = functional events; NFR-014 = security-sensitive events.
FR-018	Exact permissions undefined	High	Permissions matrix added (Section 2.7); confirmation in OI-14.
NFR-001	Vague protection mechanisms	High	Secure password hashing required; verification by inspection.
NFR-002	Protection boundary unspecified	Medium	Encryption at rest and direct-access prohibition.
NFR-003	HTTP behavior incomplete	Medium	HTTP must be rejected or redirected.
NFR-004	"Authorized AI provider" undefined	High	Authorized services listed in configuration; BR-010 created; list in OI-02.
NFR-008 / NFR-009	"Normal load" undefined	High	Normal-load test profile required (OI-15).
NFR-010	Queue failure behavior missing	Medium	Failure recording and user notification added.
NFR-011	Referenced only NFR-008	Medium	Now includes NFR-009.
NFR-012	Maintenance exclusions undefined	Medium	Maintenance must be documented in advance (OI-16).
NFR-015 / NFR-016	Backups did not ensure recovery	High / Medium	Backup monitoring and tested restoration procedure added (RTO/RPO in OI-17).
NFR-017	Validation insufficiently	Medium	Extension and MIME must both

ID	Audit Finding	Severity	Resolution in V2
	specified	m	match PDF, DOCX, or TXT.
NFR-018	"Limit AI responses" too broad	High	Rewritten as grounding + insufficient-information response.
NFR-019	"When available" weakened traceability	Medium	Document and version always stored; page/section when present.
NFR-020	Browser versions change over time	Low	Versions fixed at the start of each test cycle.
NFR-021	Referential integrity vague	Medium	Foreign-key violations must be rejected.
NFR-022	Not covered by the audit (the audit counted 21 NFRs)	-	Retained unchanged.
FR-011 / NFR-018	Inconsistent terminology	-	Standardized as "authorized organizational knowledge sources".
MoSCoW	Did not align with individual priorities	-	MoSCoW is the single priority scheme (Section 11).
Traceability	Test cases TBD; NFR/AIR not traced	-	Matrix expanded with business rules, test case IDs, and verification method (Section 13).
Global	Missing usability, privacy, scalability, maintainability requirements	-	Registered as OI-18 to OI-22 for stakeholder definition.

Requirements Traceability

Each requirement is traced as Business Objective → Requirement → Business Rule → Use Case → Test Case. Test case IDs are assigned now; their detailed procedures will be written during the testing phase. Verification methods: T = Test, I = Inspection, D = Demonstration, A = Analysis.

Objective	Requirement	Business Rule	Use Case	Priority	Test Case
SO-03	FR-001	-	UC-003	Must	TC-FR-001

Objective	Requirement	Business Rule	Use Case	Priority	Test Case
					(T)
SO-01	FR-002	BR-001	UC-001	Must	TC-FR-002 (T)
SO-01	FR-003	-	UC-001	Should	TC-FR-003 (T)
SO-01	FR-004	-	UC-001	Must	TC-FR-004 (T)
SO-01	FR-005	BR-003	UC-001	Must	TC-FR-005 (T)
SO-03	FR-006	BR-004	UC-003	Must	TC-FR-006 (T)
SO-03	FR-007	-	UC-003	Must	TC-FR-007 (T)
SO-03	FR-008	-	UC-003	Must	TC-FR-008 (D)
SO-02	FR-009	BR-002	-	Should	TC-FR-009 (T)
SO-02	FR-010	-	UC-002	Must	TC-FR-010 (D)
SO-02 / SO-05	FR-011	BR-005	UC-002	Must	TC-FR-011 (T)
SO-02 / SO-05	FR-012	-	UC-002	Must	TC-FR-012 (T)
SO-02	FR-013	BR-009	UC-002	Should	TC-FR-013 (T)
SO-03	FR-014	-	UC-003	Must	TC-FR-014 (T)
SO-03	FR-015	-	UC-003	Should	TC-FR-015 (T)
SO-03	FR-016	BR-004	UC-003	Must	TC-FR-016 (T)
SO-04	FR-017	BR-008	UC-001 / UC-003	Must	TC-FR-017 (T)
SO-04	FR-018	BR-002	UC-001 / UC-002 / UC-003	Must	TC-FR-018 (T)
SO-04	NFR-001	-	UC-001 / UC-002	Must	TC-NFR-001 (I)

Objective	Requirement	Business Rule	Use Case	Priority	Test Case
SO-04	NFR-002	-	UC-001	Must	TC-NFR-002 (T)
SO-04	NFR-003	-	All	Must	TC-NFR-003 (T)
SO-04	NFR-004	BR-010	UC-001 / UC-002	Must	TC-NFR-004 (T)
SO-04	NFR-005	-	All	Must	TC-NFR-005 (T)
SO-04	NFR-006 / NFR-007	-	All	Should	TC-NFR-006/007 (T)
SO-02	NFR-008 to NFR-011	-	UC-001 / UC-002	Should	TC-NFR-008 to 011 (T)
SO-04	NFR-012	-	All	Should	TC-NFR-012 (A)
SO-04	NFR-013	BR-003	UC-001	Must	TC-NFR-013 (T)
SO-04	NFR-014	BR-008	All	Must	TC-NFR-014 (T)
SO-04	NFR-015 / NFR-016	-	-	Must / Should	TC-NFR-015/016 (T)
SO-04	NFR-017	BR-001	UC-001	Must	TC-NFR-017 (T)
SO-05	NFR-018	BR-005, BR-007	UC-002	Must	TC-NFR-018 (T)
SO-05	NFR-019	-	UC-002	Must	TC-NFR-019 (I)
SO-02	NFR-020	-	All	Could	TC-NFR-020

Objective	Requirement	Business Rule	Use Case	Priority	Test Case
					(T)
SO-01	NFR-021 / NFR-022	-	-	Must	TC-NFR-021/022 (I)
SO-02 / SO-05	AIR-001 to AIR-008	BR-005 to BR-007, BR-009	UC-002	Must	TC-AIR-001 to 008 (T)

Scope Verification

Requirement / Feature	Scope Status	Reason
User authentication	In scope	Required for system security
Document management	In scope	Core function of the project
AI assistant	In scope	Main intelligent feature
Compliance dashboard	In scope	Part of the proposed solution
OCR	In scope	Required for scanned documents
In-application alerts	In scope	Deadline and expiration tracking (FR-015)
Email notifications	Future version	Version 1 uses in-application alerts
Native mobile application	Out of scope	The first version is web-based
Electronic signatures	Out of scope	Not part of the initial project
ERP/HRMS integration	Out of scope	External integrations are not included
Advanced multilingual support	Future version	Initial version focuses on English
Advanced reporting	Future version	Can be developed after the MVP

Open Issues

The following decisions must be made by stakeholders before the corresponding development activities begin. They consolidate the open issues of V1 and the clarification questions raised by the audit.

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
OI-01	Exact AI	AIR-002,	AI	Open	Pending

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	model to be used.	NFR-009	development		stakeholder decision
OI-02	List of AI providers authorized to process organizational documents.	NFR-004, BR-010	AI development	Open	Pending stakeholder decision
OI-03	Final vector storage solution.	NFR-019	AI development	Open	Pending stakeholder decision
OI-04	Supported notification periods; whether email will be added later.	FR-015	Alerts module	Open	Pending stakeholder decision
OI-05	AI evaluation method, relevance and accuracy thresholds, definition of a "relevant" section, and handling of conflicting documents.	FR-011, FR-012, NFR-018, AIR-008	AI testing	Open	Pending stakeholder decision
OI-06	Organization and documents to be used for testing.	AIR-008	Testing phase	Open	Pending stakeholder decision
OI-07	Final deployment	NFR-012, NFR-015	Deployment	**Resolved**	Resolved in ADR-030:

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	infrastructure.				Single VPS on DigitalOcean (4 vCPU / 8 GB RAM / 160 GB NVMe SSD) running Ubuntu 24.04 and Docker Compose; domain: compliance-platform.online; $48 USD/mo.
OI-08	Organization characteristics that affect applicability, how criteria are configured, and what happens to requirements that stop applying (removed, archived, or inactive).	FR-007	Compliance module	Open	Pending stakeholder decision
OI-09	Allowed organization types, industries, and field	FR-001	Organization module	Open	Pending stakeholder decision

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	formats.				
OI-10	Whether multiple organizations can exist in one deployment, whether a user can belong to more than one, and whether organizations can be edited, deactivated, or deleted.	FR-001, FR-018	Data model design	Open	Pending stakeholder decision
OI-11	Document categories and which categories require an expiration date.	FR-004	Document module	Open	Pending stakeholder decision
OI-12	Document deletion and archival behavior, restoring older versions, maximum number of versions, and whether expired documents remain	FR-005, BR-003	Document module	Open	Pending stakeholder decision

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	searchable.				
OI-13	Rule to decide when an uploaded document satisfies a required document.	FR-014	Compliance module	Open	Pending stakeholder decision
OI-14	Confirmation of the permissions matrix, audit-log access for Compliance Staff, and whether Management is a separate role.	FR-018, Section 2.7	Authorization design	Open	Pending stakeholder decision
OI-15	Normal-load test profile (concurrent users and request distribution).	NFR-008, NFR-009, NFR-011	Performance testing	**Resolved**	Resolved in ADR-031: 100 concurrent users; 50% dashboard/reqs, 20% search, 10% detail, 10% upload, 10% AI questions (Total 100%).
OI-16	Scheduled maintenance windows	NFR-012	Deployment	**Resolved**	Resolved in ADR-032: Maintenanc

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	and how downtime and partial degradation are measured.				e every Sunday 02:00-04:00 America/Mexico_City; downtime = any 1-minute check of GET /api/health != 200.
OI-17	Recovery time objective (RTO), recovery point objective (RPO), and backup encryption.	NFR-015, NFR-016	Deployment	**Resolved**	Resolved in ADR-033: RTO = 4 hours, RPO = 24 hours; backups encrypted with GPG AES-256 before leaving server; passphrase in team Bitwarden.
OI-18	Retention periods for audit logs and documents; privacy requirements for data deletion, export, personal-data access, and AI	NFR-001, NFR-014	Data model design	Open	Pending stakeholder decision

ID	Open Issue	Related	Needed Before	Status	Resolution / Reference
	processing of personal information.				
OI-19	Password policy, password reset, account recovery, and security incident handling.	NFR-005, NFR-006	Authentication module	Open	Pending stakeholder decision
OI-20	Usability and accessibility requirements (error messages, navigation, form validation, accessibility standard).	All UI requirements	UI design	Open	Pending stakeholder decision
OI-21	Scalability targets for documents, storage, organizations, AI requests, and compliance requirements.	NFR-011	Architecture design	Open	Pending stakeholder decision
OI-22	Measurable maintainability requirements.	NFR-021, NFR-022	Architecture design	Open	Pending stakeholder decision

Approval and Validation

Before development starts, the requirements shall be reviewed by the project team and, when possible, by the organization's representatives. V2 already incorporates the findings of the requirements audit; the remaining open issues (Section 15) must be resolved and reflected in a later version.

The team shall verify that the requirements are:

- Correct
- Complete
- Consistent
- Unambiguous
- Verifiable
- Feasible
- Traceable
- Properly prioritized

The final goal is that the stakeholders and the development team have the same understanding of what the system needs to accomplish.